

CYBER.SOHO EDUCATIONAL HUB

Day 16 — Endpoint Security

Mobile · IoT · OT/ICS

Incident Handling & Response · Week 9 · Class 1

1-hour lecture block



Where we are in the term

From the centre of the network to the edge

- Weeks 1–8 covered: malware, phishing, web tier, network, insiders
- Week 9 today: **endpoint security** at the edge
- Week 9 next class: Mobile & IoT Forensics and Analysis
- Week 10: Final review and Final exam

KEY TAKEAWAY

Today we walk from the data-centre to the EDGE — phones, cameras, PLCs. All endpoints. None behave like a laptop.

The casino fish-tank thermometer (2017)

Why this hour matters

- A North American casino lost **~10 GB** of high-roller records
- Beachhead was an **internet-connected fish-tank thermometer**
- Vendor placed it on the corporate Wi-Fi
- Attacker pivoted laterally through a flat network
- Four hops to the high-roller database

Why we all would have missed it

- IT did not know the thermometer existed
- Security tooling did not run on the thermometer
- No agent, no patch, no logs to read
- The device did exactly what it was sold to do — nothing else

KEY TAKEAWAY

Endpoints are computers nobody treats like computers. The blind spot IS the lesson.

Today's five learning objectives

Lifted straight off the syllabus

- Examine unique security challenges of mobile, IoT, and OT/ICS
- Identify common vulnerabilities and expanded attack surfaces
- Adapt IR procedures for resource-constrained and legacy endpoints
- Evaluate Mobile Device Management (MDM) and Endpoint Detection & Response (EDR) tools
- Review IEC 62443 and NIST SP 800-82

01

LESSON 1

Unique security challenges of mobile, IoT, and OT/ICS

Three families, three threat models, three patch cadences

Three families of endpoints

Same network, three completely different defences

- **Mobile** — phones, tablets, company laptops
- **IoT** — cameras, badge readers, HVAC sensors
- **OT/ICS** — PLCs, SCADA, HMIs on the plant floor
- All three are little boxes with IP addresses
- Almost nothing else in common

The Mobile family

Human-owned, well-patched, familiar threats

- **Owner:** the human carrying the device
- **Crown jewels:** corporate email, MFA push, camera, mic, GPS
- **Threats:** smishing, sideloaded apps, lost or stolen, zero-click chains
- **Patch cadence:** monthly — best of the three
- **Defence anchor:** Mobile Device Management (MDM) + conditional access

The IoT family

No clear owner — the device itself is the prize

- **Owner:** ambiguous — facilities, vendor, 'nobody'
- **Crown jewels:** the *device* — recruited into botnets
- **Reference incident:** Mirai (2016) took down Dyn DNS via cameras
- **Patch cadence:** one firmware update per device lifetime, if any
- **Defence anchor:** network segmentation and discovery

The OT/ICS family

Controls physical reality, not data

- **Owner:** plant engineering, not IT
- **Crown jewels:** *physics* — temperatures, speeds, chemistry
- **Acronyms to know:** PLC, SCADA, HMI, DCS, SIS
- **Reference incident:** Triton/TRISIS (2017) — targeted the safety system itself
- **Patch cadence:** yearly during turnaround, or never

Patch cadence comparison

Why the same vulnerability lives 1000× longer in OT

Family	Patch cadence	Window to fix
Mobile	Monthly	Days, with MDM
IoT	One firmware per lifetime	Years
OT/ICS	Yearly turnaround	Years or never

The unifying truth

One sentence that frames the next four lessons

- All three families live on the same network as your laptop
- But you **cannot defend them the same way**
- No EDR agent ever runs on a PLC
- No analyst remotes into a smart bulb
- Defence must come from the **network around** the device

KEY TAKEAWAY

Three families, three threat models, three patch cadences — but ONE shared problem: you can't put your usual tools on any of them.

02

LESSON 2

Common vulnerabilities and the expanded attack surface

What happens when the families share a flat network

The attack surface has exploded

From one device per employee to twenty

- 1995 corporate network: ~1 IP-connected device per employee
- 2025 corporate network: 5–20 per employee
- Every printer, camera, badge reader, UPS, smart bulb counts
- The microcontroller in the badge talks to a server
- The surface grows faster than the defence

Common weaknesses (1/2)

The 1998 pen-test report, still relevant in 2026

- **Default credentials** — admin/admin, root/root (Mirai used 61 hard-coded pairs)
- **Unauthenticated management interfaces** — web UI on port 80, no login
- **Unsigned firmware** — push any blob, the device reflashes
- **Cleartext protocols** — Modbus, DNP3, BACnet without authentication or encryption

Common weaknesses (2/2)

The catalogue, continued

- **Hardcoded backdoor accounts** — vendor 'service' accounts the customer was never told about
- **No customer-readable logs or telemetry** — whatever happens on the device, stays there
- See CISA ICS Advisories for the rolling list of disclosures
- Every item above is preventable — none of them are, in practice

The flat network multiplier

Why one weak speck becomes a breach

- Lobby Wi-Fi reachable from sensor VLAN
- Sensor VLAN reachable from printer VLAN
- Printer VLAN reachable from finance
- ≈ half of mid-sized companies look like this
- The aquarium pivot needed one weak speck — and no segmentation

The blast radius question

Reframe the inventory problem

- **Wrong question:** 'Do we have an exposed weak device?'
- **Right question:** 'Does our network contain the blast radius?'
- The answer to the wrong question is always 'yes'
- The answer to the right question is testable, fixable, fundable

KEY TAKEAWAY

Assume the weak endpoint exists. Engineer the SEGMENTATION that makes it irrelevant.

03

LESSON 3

Adapting IR for resource-constrained and legacy endpoints

The NIST 800-61 playbook BENDS — it does not break

NIST SP 800-61r2 assumes a normal computer

The six classic phases — about to be translated

1. Preparation
2. Identification
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

KEY TAKEAWAY

The playbook is not thrown out — it is ADAPTED.

Preparation adapted

Position the network, not the agent

- Classic move: push an EDR agent
- Adapted move: position the **network** to see the device
- Span ports on the switch closest to the OT cell
- Syslog from the IoT vendor's cloud console
- NetFlow at the upstream firewall
- Collect the telemetry that flows *past* the device

Identification adapted

The PLC won't tell you — its neighbour will

- Classic move: pull a process tree
- Adapted move: correlate **ambient telemetry** with two extra channels
- Vendor's cloud console (if it exists)
- Engineering workstation logs
- The PLC stays silent; the workstation that talked to it does not

Containment adapted

Quarantine the path, not the device

- Classic move: isolate the host
- Adapted move: cut **the path**, leave the device running
- Change a switch ACL (Access Control List)
- Micro-segment the conduit
- Drop the Command-and-Control (C2) channel at the firewall
- The plant manager is not woken up at 3am

Eradication adapted

There is nothing to 'remove' from a PLC

- Firmware is OS + application + persistence, all in one blob
- Reflash to a known-good vendor image
- Factory reset
- Rotate any shared cryptographic material
- Coordinated change with the vendor on the call
- It is **not** taskkill /F

Recovery adapted

The window is whatever the business says it is

- Recovery is governed by operations, not by you
- The plant has a turnaround schedule
- The hospital has a surgery list
- The data centre has an availability target
- **Your job:** be ready for that window the moment it opens

Lessons Learned + the one extra step

Fix the asset inventory FIRST

- The device that got compromised was almost certainly not on the list
- If you do not update the list, the next breach hits the next un-listed device
- You cannot defend what you never inventoried
- Write that on the wall of your SOC

KEY TAKEAWAY

Don't throw out NIST 800-61. TRANSLATE every phase. And always start with the inventory.

04

LESSON 4

Evaluating MDM platforms and EDR tools

Two acronyms, two verbs, small overlap

MDM and EDR are not the same thing

They overlap — but the overlap is small

- **MDM** — *manage* device identity and posture
- **EDR** — *detect and respond* to device behaviour
- They overlap, but the overlap is small
- Most mature shops need **both**, configured deliberately
- Confusing them costs companies real money

MDM scope

Identity, posture, enrolment — verb: manage

- Enrolment and inventory
- App-store policy
- Passcode requirements
- Encryption-at-rest enforcement
- Remote wipe and geofencing
- Jailbreak and root detection
- VPN and Wi-Fi profile push

EDR scope

Behaviour, detection, response — verb: detect & respond

- Process telemetry
- Behavioural detection and memory scanning
- File and registry Indicators of Compromise (IOCs)
- Live response shell
- Network containment
- Threat-hunting queries
- Post-incident timeline reconstruction

The true overlap

The list every procurement exercise should start from

1. Asset inventory
2. Compliance reports
3. Posture signal for conditional access
4. Log forwarding to a SIEM
5. Role-based admin

KEY TAKEAWAY

Buy each capability ONCE. Don't double-pay in the overlap and leave gaps in the unique zones.

North American MDM landscape

Common platforms in 2026

- **Microsoft Intune** — broadest enterprise reach
- **Jamf** — Apple-heavy shops
- **VMware Workspace ONE** — UEM (Unified Endpoint Management) generalisation
- Trend: **UEM** has effectively absorbed the 'MDM' label

North American EDR landscape

Common platforms in 2026

- CrowdStrike Falcon
- Microsoft Defender for Endpoint
- SentinelOne
- Sophos Intercept X
- Trend Micro Apex One
- Names will rotate. The *verb* will not.

Two sentences about the same device

The five-years-ahead-of-classmates test

- **MDM sentence:** 'The phone is encrypted, passcode-protected, and not jailbroken.'
- **EDR sentence:** 'The phone is calling out to a known C2 IP at 3am.'
- A good security program needs **both being true at the same time**

KEY TAKEAWAY

MDM is the posture story. EDR is the behaviour story. Buy each capability once. Tell both stories about every device.

05

LESSON 5

Regulatory standards for IoT and OT security

IEC 62443 and NIST SP 800-82

Two standards you must know exist

You won't memorise them. You will recognise them.

- **IEC 62443** — international standard for Industrial Automation and Control Systems Security
- **NIST SP 800-82** — Guide to Operational Technology Security
- Reference documents — they tell you *roughly which section to flip to*
- Used to answer 'are we compliant?' on day one of an engagement

IEC 62443 structure

Four parts, four audiences

- **62443-1-x** — terminology and concepts ('what is an IACS?')
- **62443-2-x** — what the **owner-operator** must do (policies, programs)
- **62443-3-x** — what the **system integrator** designs (zones, conduits, security levels)
- **62443-4-x** — what the **product vendor** bakes into the PLC or HMI to certify it
- Published by the International Electrotechnical Commission (IEC)

The one sub-standard for IR

Seven Foundational Requirements (FR1–FR7)

- Most useful sub-standard for an incident handler
- Lists **System Requirements (SRs)**, grouped under FR1–FR7
- Maps almost one-for-one to NIST SP 800-53 controls
- Forms the basis of any OT compliance scorecard
- Flip here first when asked 'where do we start?'

NIST SP 800-82r3

Tailoring guide, not a competitor to IEC 62443

- Published by NIST — revision 3 released 2023
- Scope broadened from 'ICS' to 'OT' — covers IoT, building automation, medical devices
- Explains how to apply **NIST SP 800-53** controls in an OT setting
- **Federal US work:** 800-82 is what the auditor hands you
- **Certified product work internationally:** IEC 62443
- In practice, cite both

ETSI EN 303 645

European baseline for consumer IoT

- Published by the European Telecommunications Standards Institute (ETSI)
- Source of the 'no default passwords' rule
- Source of much of the IoT marketing copy you will see
- Know the name; know who publishes it — that is enough at this level

Standards as deployable engineering

The point of the checklist

- Standards are not academic
- They are the **checklist** a defender turns into an engineering plan
- Map site policy answers → matching SR → matching control
- Score pass / partial / fail
- The percentage at the bottom is **not a finish line** — it is a *direction of travel*

KEY TAKEAWAY

IEC 62443 + NIST SP 800-82 are the two documents you CITE. They turn opinion into engineering.

What to take home

Five lessons, one underlying message

- Endpoints are not what they used to be
- The IR playbook **bends**, it does not break
- A 2026 incident handler walks into a site with three families
- Three patch cadences, three threat actors, two standards
- (IEC 62443 and NIST SP 800-82)

The job is the gap

Done is better than perfect

- The customer's posture will fall short on **every** axis
- That is the job — **not perfection**
- Pragmatic, measured progress on the right axes
- That is what a senior incident handler delivers

KEY TAKEAWAY

Walk in with a model. Measure against the standards. Move the right axes first. Done is better than perfect.

Mobile & IoT Forensics and Analysis

What to bring on Friday

- We dig into what you actually **pull off** these devices
- Bring the laptop
- Bring the lab VM
- Bring the assets CSV from today's first exercise — we will reuse it

Standards bodies and primary documents

Bookmark these

- **IEC** — IEC 62443 family — iec.ch
- **ISA** — co-publisher in the US — isa.org
- **NIST** — SP 800-82r3, SP 800-61r2, SP 800-53, SP 800-124r2
- **ETSI** — EN 303 645 — etsi.org
- **CISA** — ICS advisories — cisa.gov

Vendors mentioned (no endorsement)

For evaluation purposes only

- **Microsoft Intune** — learn.microsoft.com/en-us/mem/intune
- **Jamf** — jamf.com
- **VMware Workspace ONE** — vmware.com
- **Microsoft Defender for Endpoint** — microsoft.com
- **CrowdStrike Falcon** — crowdstrike.com
- **SentinelOne** — sentinelone.com
- **Sophos Intercept X** — sophos.com
- **Trend Micro Apex One** — trendmicro.com

Incidents, RFCs, and pre-class link safety

Background reading + the URL-hygiene reflex

- **Mirai botnet** — US-CERT TA16-288A
- **RFC 3227** — Evidence collection order
- **RFC 5737** — Documentation IP ranges
- **IANA** — iana.org
- **Dragos** — ICS / OT threat intelligence
- Before clicking ANY link from a corporate machine: run it through **VirusTotal URL scanner**
- The reflex IS the lesson

Intellectual property and affiliations

Cyber.SoHo is independent

- All material © **Cyber.SoHo Educational Hub** — sole creator and owner
- Cyber.SoHo is an **independent educational brand**
- Not affiliated with, sponsored by, or endorsed by any cited organisation, vendor, or standards body
- Citations are references for further study — no endorsement implied
- Third-party YouTube content remains the property of its publishers

Authorisation, legality, and liability

Lab use only — written authorisation required

- Scripts are illustrative teaching artifacts — **lab use only**
- Run only against systems you own, or for which you hold **written authorisation**
- Unauthorised use is a criminal offence under:
- **Canadian Criminal Code s.342.1** — Unauthorized Use of Computer
- **US CFAA (18 U.S.C. § 1030)** — Computer Fraud and Abuse Act
- **EU Directive 2013/40/EU** — Attacks Against Information Systems
- **Spain Ley Orgánica 10/1995** — artículos 197 bis and 197 ter
- Cyber.SoHo disclaims all liability for use outside an authorised educational context

CYBER.SOHO EDUCATIONAL HUB

Thank you

Cyber.SoHo Educational Hub

- Day 16 of Incident Handling & Response
- Questions: see lab session and discussion forum
- Next class: **Mobile & IoT Forensics and Analysis**

